

THIRD-PARTY RISK ASSESSMENT REPORT

Vendor Risk Assessment

MedBill Pro Solutions — Healthcare IT Vendor

Conducted by: White Plains Hospital — GRC Program

VENDOR INFORMATION

Vendor Name	MedBill Pro Solutions LLC
Service Provided	Electronic Health Record (EHR) Billing and Revenue Cycle Management
Data Accessed	Patient PHI — demographics, diagnoses, insurance, billing records
BAA Status	SIGNED — April 1, 2026
Contract Value	\$280,000 annually
Contract Period	April 2026 — March 2029 (3 years)
Vendor HQ	Austin, Texas
Employee Count	Approximately 450 employees
PHI Access Level	HIGH — Full access to patient billing records and insurance data
Vendor Tier	TIER 1 — Critical vendor requiring full assessment

ASSESSMENT INFORMATION

Assessed By	Nadhir Choudhury — GRC Analyst, White Plains Hospital
Assessment Date	April 2026
Assessment Method	Security questionnaire + document review + SOC 2 report analysis
Framework Applied	HIPAA Security Rule NIST CSF Vendor Risk Management Best Practices
Total Questions	36 questions across 7 risk categories
Assessment Score	171 / 180 (95%)
Gaps Identified	4 gaps requiring remediation
Classification	CONFIDENTIAL — Internal Use Only

ASSESSMENT RESULT: APPROVED | Score: 95% (171/180)

Vendor meets security requirements. Proceed with contract. Annual review required.

DISCLAIMER

This vendor risk assessment was created for educational and portfolio demonstration purposes only. MedBill Pro Solutions is a fictional vendor. All findings, scores, and recommendations are fictional and do not represent actual vendor assessments. Do not use in a real production or regulatory environment.

WHITE PLAINS HOSPITAL VENDOR SECURITY QUESTIONNAIRE MedBill Pro Solutions April 2026							
5 = Fully Met		Mostly Met	3 = Partially Met	Mostly Not Met	Not Met	0 = No Response	
#	SECURITY QUESTION	Max Score	VENDOR RESPONSE	Score Given	Score %	Gap?	ASSESSOR NOTES
ORGANIZATIONAL SECURITY							
1	Does your organization have a formally documented Information Security Policy?	5	Yes — ISO 27001 aligned policy reviewed annually	5	100%	No	Strong. Policy is documented, approved, and regularly reviewed.
2	Is there a designated Chief Information Security Officer (CISO) or equivalent?	5	Yes — CISO appointed with dedicated security team of 8 staff	5	100%	No	Excellent. Dedicated security leadership in place.
3	Does your organization conduct annual security risk assessments?	5	Yes — annual risk assessments conducted and documented	5	100%	No	Compliant. Risk assessments are conducted and documented annually.
4	Have you had any data breaches or security incidents in the past 3 years?	5	One minor phishing incident in 2023 — contained within 4 hours, no PHI exposed	3	60%	YES	Acceptable. Incident was minor and handled promptly. Request incident report.
5	Do you carry cyber liability insurance?	5	Yes — \$5 million cyber liability coverage with AIG	5	100%	No	Strong. Adequate cyber insurance coverage confirmed.
6	Do you conduct annual security awareness training for all staff?	5	Yes — mandatory training with phishing simulations quarterly	5	100%	No	Excellent. Comprehensive training program with practical simulations.
DATA PROTECTION & PRIVACY							
7	Do you have a documented data classification policy?	5	Yes — four-tier data classification policy in place	5	100%	No	Strong. Formal data classification aligns with HIPAA requirements.
8	Is all Protected Health Information (PHI) encrypted at rest?	5	Yes — AES-256 encryption applied to all PHI storage	5	100%	No	Compliant. AES-256 encryption meets HIPAA technical safeguard requirements.
9	Is PHI encrypted in transit between your systems and client systems?	5	Yes — TLS 1.3 enforced on all PHI transmissions	5	100%	No	Excellent. Modern TLS 1.3 encryption for all data in transit.
10	Do you have a documented data retention and disposal policy?	5	Yes — 7 year retention policy with certified destruction for disposal	5	100%	No	Compliant. Retention policy meets HIPAA 6-year minimum requirement.
11	Do you have a formal data breach response plan?	5	Yes — documented IRP with 72-hour notification procedures	5	100%	No	Strong. Breach response plan covers both HIPAA and GDPR notification timelines.
12	Do you limit employee access to PHI based on job role (minimum necessary)?	5	Yes — role-based access control with quarterly access reviews	5	100%	No	Compliant. Minimum necessary standard enforced through RBAC.

WHITE PLAINS HOSPITAL VENDOR SECURITY QUESTIONNAIRE MedBill Pro Solutions April 2026							
5 = Fully Met		Mostly Met	3 = Partially Met	Mostly Not Met	Not Met	0 = No Response	
#	SECURITY QUESTION	Max Score	VENDOR RESPONSE	Score Given	Score %	Gap?	ASSESSOR NOTES
ORGANIZATIONAL SECURITY							
1	Does your organization have a formally documented Information Security Policy?	5	Yes — ISO 27001 aligned policy reviewed annually	5	100%	No	Strong. Policy is documented, approved, and regularly reviewed.
2	Is there a designated Chief Information Security Officer (CISO) or equivalent?	5	Yes — CISO appointed with dedicated security team of 8 staff	5	100%	No	Excellent. Dedicated security leadership in place.
13	Is multi-factor authentication (MFA) required for all PHI system access?	5	Partially — MFA on primary systems. Legacy billing module not yet upgraded.	2	40%	YES	GAP IDENTIFIED. Legacy system lacks MFA. Require remediation timeline.
14	Do you conduct Privacy Impact Assessments for new systems handling PHI?	5	Yes — PIA conducted for all new systems before deployment	5	100%	No	Strong. Proactive privacy impact assessment process in place.
ACCESS CONTROL & IDENTITY							
15	Are all user accounts unique — no shared accounts permitted?	5	Yes — unique accounts required. Shared accounts prohibited by policy.	5	100%	No	Compliant. Unique user identification meets HIPAA Security Rule §164.312(a)(2)(i).
16	Do you have a formal process for onboarding and offboarding user access?	5	Yes — automated provisioning and deprovisioning linked to HR system	5	100%	No	Excellent. Automated offboarding reduces risk of orphaned accounts.
17	Are privileged accounts managed separately from standard user accounts?	5	Yes — PAM solution in place with just-in-time privileged access	5	100%	No	Strong. Privileged Access Management reduces insider threat risk.
18	Do you conduct quarterly user access reviews?	5	Yes — quarterly access certifications for all PHI systems	5	100%	No	Compliant. Regular access reviews meet HIPAA administrative safeguard requirements.
19	Are audit logs maintained for all PHI access and activity?	5	Yes — immutable audit logs retained for 7 years	5	100%	No	Excellent. Comprehensive audit logging with long-term retention.
NETWORK & INFRASTRUCTURE							
20	Is your network segmented to isolate PHI systems from general network traffic?	5	Yes — PHI systems in dedicated VLAN with firewall controls	5	100%	No	Strong. Network segmentation reduces blast radius of potential breach.
21	Do you conduct regular vulnerability scanning of PHI systems?	5	Yes — weekly automated scans and quarterly manual penetration testing	5	100%	No	Excellent. Comprehensive vulnerability management program.

WHITE PLAINS HOSPITAL | VENDOR SECURITY QUESTIONNAIRE | MedBill Pro Solutions | April 2026

5 = Fully Met		Mostly Met	3 = Partially Met	Mostly Not Met	= Not Met	0 = No Response	
#	SECURITY QUESTION	Max Score	VENDOR RESPONSE	Score Given	Score %	Gap?	ASSESSOR NOTES
ORGANIZATIONAL SECURITY							
1	Does your organization have a formally documented Information Security Policy?	5	Yes — ISO 27001 aligned policy reviewed annually	5	100%	No	Strong. Policy is documented, approved, and regularly reviewed.
2	Is there a designated Chief Information Security Officer (CISO) or equivalent?	5	Yes — CISO appointed with dedicated security team of 8 staff	5	100%	No	Excellent. Dedicated security leadership in place.
22	Do you have an intrusion detection or prevention system (IDS/IPS)?	5	Yes — enterprise IDS/IPS monitored 24/7 by SOC	5	100%	No	Strong. 24/7 SOC monitoring provides continuous threat detection.
23	Is there a patch management policy with defined timelines?	5	Yes — critical patches within 24 hours, high within 72 hours, medium within 30 days	5	100%	No	Compliant. Patch timelines align with industry best practice.
24	Do you have a tested disaster recovery and business continuity plan?	5	Yes — DR tested annually. RTO 4 hours, RPO 1 hour for PHI systems	5	100%	No	Excellent. Tested DR with aggressive RTO/RPO targets for PHI availability.
25	Is remote access to PHI systems restricted to VPN with MFA?	5	Yes — VPN with MFA required. Direct remote access to PHI prohibited.	5	100%	No	Strong. Remote access controls meet HIPAA technical safeguard requirements.
COMPLIANCE & CERTIFICATIONS							
26	Do you hold a current SOC 2 Type 2 certification?	5	Yes — SOC 2 Type 2 report available. Last audit: November 2025.	5	100%	No	Excellent. SOC 2 Type 2 provides independent assurance of control effectiveness.
27	Are you HIPAA compliant and willing to sign a Business Associate Agreement?	5	Yes — HIPAA compliance program in place. BAA signed as standard practice.	5	100%	No	Compliant. BAA agreement in place meets HIPAA organizational requirements.
28	Have you undergone a third-party HIPAA assessment in the past 2 years?	5	Yes — external HIPAA assessment conducted Q3 2025. No critical findings.	5	100%	No	Strong. Recent independent HIPAA assessment with clean results.
29	Do you conduct background checks on all employees with PHI access?	5	Yes — criminal background checks for all staff before PHI access granted	5	100%	No	Compliant. Background check process meets workforce clearance requirements.
30	Do you have a subcontractor management program for fourth-party risk?	5	Partially — primary subcontractors reviewed but no formal fourth-party program	2	40%	YES	GAP IDENTIFIED. Fourth-party risk not formally managed. Requires improvement.
PHYSICAL SECURITY							

WHITE PLAINS HOSPITAL VENDOR SECURITY QUESTIONNAIRE MedBill Pro Solutions April 2026							
5 = Fully Met		Mostly Met	3 = Partially Met	Mostly Not Met	Not Met	0 = No Response	
#	SECURITY QUESTION	Max Score	VENDOR RESPONSE	Score Given	Score %	Gap?	ASSESSOR NOTES
ORGANIZATIONAL SECURITY							
1	Does your organization have a formally documented Information Security Policy?	5	Yes — ISO 27001 aligned policy reviewed annually	5	100%	No	Strong. Policy is documented, approved, and regularly reviewed.
2	Is there a designated Chief Information Security Officer (CISO) or equivalent?	5	Yes — CISO appointed with dedicated security team of 8 staff	5	100%	No	Excellent. Dedicated security leadership in place.
31	Are data centers and server rooms protected with physical access controls?	5	Yes — biometric access, CCTV, and security guards at all data center locations	5	100%	No	Excellent. Multi-layered physical security controls at all PHI processing locations.
32	Are physical media containing PHI subject to secure disposal procedures?	5	Yes — NIST 800-88 certified data destruction for all physical media	5	100%	No	Strong. NIST-compliant media disposal process confirmed.
33	Do you have environmental controls protecting PHI systems (fire, flood, power)?	5	Yes — Tier 3 data center with redundant power, cooling, and fire suppression	5	100%	No	Excellent. Tier 3 data center provides high availability and environmental protection.
VENDOR & CONTRACT MANAGEMENT							
34	Do you maintain a complete inventory of all subcontractors handling PHI?	5	Yes — formal subcontractor register with annual review process	4	80%	YES	Good. Subcontractor register maintained but fourth-party risk program incomplete.
35	Do you require all subcontractors handling PHI to sign BAAs?	5	Yes — BAA required as contractual condition for all PHI-handling subcontractors	5	100%	No	Compliant. BAA flow-down requirements protect White Plains Hospital.
36	What is your average response time to a client security incident notification?	5	Within 24 hours for all security incidents. PHI breaches within 4 hours.	5	100%	No	Excellent. Rapid incident notification timelines exceed HIPAA requirements.
TOTAL ASSESSMENT SCORE		180		171	95%	4 gaps	

OVERALL VENDOR RISK SCORE

95%

✓ VENDOR APPROVED

Vendor meets security requirements for handling PHI. Proceed with contract. Schedule annual review.

SCORING METRICS

Questions Asked	Total Points	Score Achieved	Gaps Found	Score %
36	180	171	4	95%

SCORE BY RISK CATEGORY						
Risk Category	Questions	Max Score	Score	Score %	Gaps	Rating
Organizational Security	6	30	28	93%	1	Low Risk
Data Protection & Privacy	8	40	37	92%	1	Low Risk
Access Control & Identity	5	25	25	100%	0	Low Risk
Network & Infrastructure	6	30	30	100%	0	Low Risk
Compliance & Certifications	5	25	22	88%	1	Low Risk
Physical Security	3	15	15	100%	0	Low Risk
Vendor & Contract Management	3	15	14	93%	1	Low Risk

GAPS IDENTIFIED — REMEDIATION REQUIRED						
#	Category	Question Summary	Vendor Score	Max Score	Gap	Action Required
1	Organizational Security	Have you had any data breaches or security incidents in the ...	3	5	-2	Acceptable.
2	Data Protection & Privacy	Is multi-factor authentication (MFA) required for all PHI sy...	2	5	-3	GAP IDENTIFIED.
3	Compliance & Certifications	Do you have a subcontractor management program for fourth-pa...	2	5	-3	GAP IDENTIFIED.
4	Vendor & Contract Management	Do you maintain a complete inventory of all subcontractors h...	4	5	-1	Good.

RESIDUAL RISK ASSESSMENT (POST-REMEDIATION)
(98.9%) — LOW RISK

WHITE PLAINS HOSPITAL | VENDOR RISK ASSESSMENT FORMAL REPORT | April 2026

1. EXECUTIVE SUMMARY

White Plains Hospital conducted a vendor risk assessment of MedBill Pro Solutions LLC, a healthcare IT vendor providing EHR billing and revenue cycle management services. The assessment evaluated 36 security controls across 7 risk categories using a structured security questionnaire, SOC 2 Type 2 review, and document analysis. The vendor achieved a score of 95% (171/180 points), with 4 gaps identified. The assessment result is: APPROVED.

2. FORMAL RECOMMENDATION

RECOMMENDATION: APPROVED

Vendor meets security requirements for handling PHI. Proceed with contract. Schedule annual review.

3. CONDITIONS AND REQUIREMENTS

REQUIRED BEFORE CONTRACT SIGNING

Signed Business Associate Agreement (BAA) — confirming PHI protection obligations

Copy of current SOC 2 Type 2 report — dated within 12 months

Confirmation of cyber liability insurance coverage of minimum \$5 million

Completed and signed security questionnaire with attestation

REQUIRED WITHIN 90 DAYS OF CONTRACT START

Remediation plan for identified gaps — specifically MFA on legacy billing module

Fourth-party risk management program — documenting all subcontractors handling PHI

Annual security assessment schedule — including dates and assigned contacts

ONGOING REQUIREMENTS — THROUGHOUT CONTRACT PERIOD

Annual vendor reassessment — using this questionnaire framework

Incident notification to White Plains Hospital within 4 hours of any PHI incident

Annual SOC 2 Type 2 report provided to White Plains Hospital GRC team

Notification of any material change to security controls, ownership, or subcontractors

4. IDENTIFIED GAPS AND REMEDIATION REQUIREMENTS

Gap #	Category	Gap Description	Current Score	Priority	Remediation Action	Due Date
1	Organizational Security	One minor phishing incident in 2023. Contained in 4 hours. No PHI exposed. Post-incident review documentation not yet provided to WPH.	3/5	Medium	Incident post-incident review report. Confirm no PHI was exposed. Add as annual requirement in contract.	90 days
2	Data Protection & Privacy	MFA not implemented on legacy billing module. This system processes PHI. Authentication relies on password only.	2/5	High	Legacy billing module within 30 days of contract signing. Set hard completion deadline of 90 days.	90 days
3	Compliance & Certifications	No formal fourth-party risk program. Subcontractors handling PHI are not all assessed. Risk of uncontrolled PHI access through supply chain.	2/5	High	Within 90 days, all PHI-handling subcontractors must have BAAs in place and be documented by contract end of Year 1.	90 days
4	Vendor & Contract Management	Subcontractor register exists but fourth-party risk assessment program is incomplete. Annual review process not formalized.	4/5	Medium	Confirm fourth-party register is current and shared with WPH annually. Include in annual review checklist.	90 days

5. SOC 2 TYPE 2 REVIEW FINDINGS

— November 2025). The following key findings were noted during review:

Trust Service CriteriaSecurity (CC), Availability (A), Confidentiality (C) — all three applicable criteria included

Auditor Opinion:Unqualified opinion — no material control failures noted during audit period

Control ExceptionsNoneZero control exceptions noted for Security and Confidentiality criteria corrected during audit

Availability ExceptionNoneparty program gap noted

Subprocessors ListNone(see Gap #3)

WPH Assessment:

5. ASSESSMENT SIGNATURES

Assessed By	Nadhir Choudhury — GRC Analyst	Date: April 2026	
Reviewed By	Chief Information Security Officer	Date: _____	
Approved By	Chief Compliance Officer	Date: _____	
Vendor Acknowledged By	MedBill Pro Solutions — Security Officer	Date: _____	

White Plains Hospital GRC Program | Nadhir Choudhury | Educational purposes only